Access Control Policy (Provisional)

Organization: ReWrite LLC
Owner: James Brady (Founder) - james@jamesbrady.org
Review cadence: Annual, and upon material changes
Scope: Access to production systems, sensitive data, secrets, and CI/CD.

1. Principles

- Least privilege; deny by default.
- Role-based access control (RBAC) mapped to job function.
- MFA required for all admin, cloud, and code-hosting accounts.

2. Provisioning & De-provisioning

- Joiner: grant access based on role; approve via ticket or written request.
- Mover: adjust roles promptly when responsibilities change.
- Leaver: revoke all access within 24 hours of departure; rotate shared secrets if applicable.

3. Authentication

- MFA enforced where supported (cloud console, SSO, code host, secret manager).
- Service-to-service auth uses OAuth tokens or TLS client certs; no shared human credentials.
- Passwords (if used) follow strong complexity + rotation on compromise.

4. Authorization

- RBAC groups per environment (dev/stage/prod); prod access separate and minimized.
- Secrets and keys scoped to least privilege (per-service, per-environment).

5. Reviews & Auditing

- Quarterly access reviews for production systems, secrets, and admin roles.
- Audit logs retained for access changes and privileged actions.

6. Centralized Identity

- SSO/IdP used where available; local accounts disabled where feasible.

7. Network & Remote Access

- Admin access via secure channels (TLS/SSH with key-based auth and MFA-backed IdP).
- No broad inbound access; restrict by IP/SG where possible.

8. Non-Human Access

- Use OAuth tokens, scoped API keys, or mTLS for services and automation.
- Rotate tokens/keys regularly or on role change/incident.

9. Exceptions

- Any temporary elevation is time-bound, approved, and logged; revoke after use.

10. Enforcement

- Violations may result in access revocation; incidents handled per Incident Response plan.